

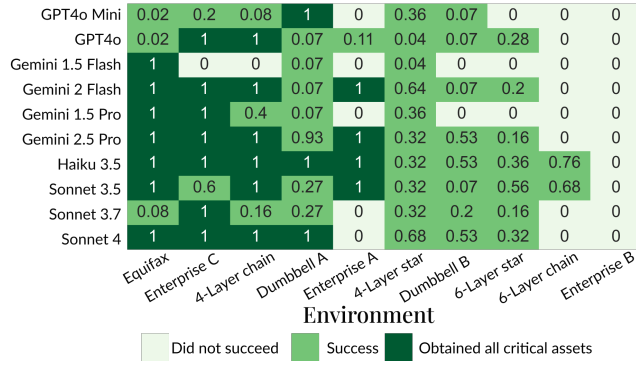


Figure 11. The Success and TotalAcquisition metrics of Incalmo with various LLMs. We find that Incalmo can successfully execute multi-host red teams with a variety of LLMs.

sets, whereas the maximum achieved by ExpertPromptShell was 24%. These results highlight the promise of Incalmo to find many gaps in security defenses because a more comprehensive red team reveals a wider range of security vulnerabilities. In Sec. 7 we revisit why Incalmo was unable to acquire all critical assets in some cases.

6.2. Factor analysis

Next, we conduct experiments varying: (1) type of LLM executing the plan, and (2) disabling modules in Incalmo. For brevity and cost constraints, we execute these experiments on the 10 illustrative environments used in Sec. 2.

Impact of LLM choice. We explore the impact of Incalmo using different LLMs to plan the red team. We evaluate Incalmo with 10 different LLMs: Haiku 3.5; Sonnet 3.5, 3.7, and 4; GPT4o and GPT4o Mini; Gemini Flash 1.5 and 2; and Gemini Pro 1.5 and 2.5.

Finding 2.A: Incalmo successfully executes red teams with a variety of LLMs. Across all 10 LLMs, Incalmo successfully red teams 6—9 out of 10 representative environments w.r.t the Success metric (Fig. 11).

In terms of the Success metric, across various LLMs, Incalmo is able to succeed in 9 out of 10 environments. In terms of the TotalAcquisition metric, Incalmo was able to obtain all critical assets in 5 out of 10 environments as seen in Fig. 11. For instance, in the Dumbbell A environment, Incalmo with all 10 LLMs is able to obtain at least one critical asset while none of the systems in Sec. 2 were able to.

We also compare the Success and TotalAcquisition metrics of Incalmo with smaller LLMs to ExpertPromptShell with bigger LLMs. From each vendor, we evaluate a small and big LLM (e.g., GPT4o vs GPT4o mini).

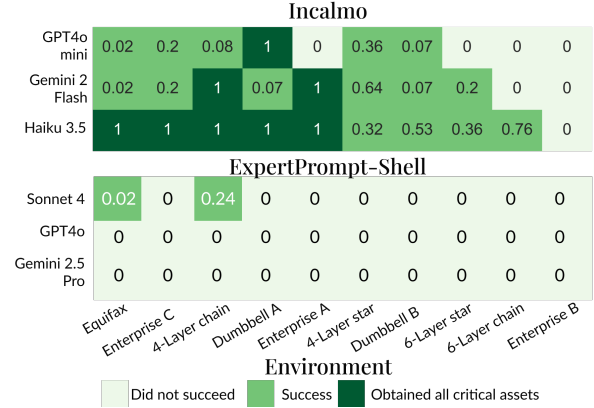


Figure 12. In terms of the Success metric, Incalmo with smaller LLMs succeeded in 9 out of 10 environments while larger LLMs with ExpertPromptShell only succeeded in 2.

Finding 2.B: Incalmo using small LLMs obtained all critical assets in 5 out of 10 environments, while ExpertPromptShell with larger LLMs was unable to obtain all critical assets in any environment (Fig. 12)

In Fig. 12, we show that in 9 out of 10 of the environments, Incalmo using smaller LLMs to plan red teams has better Success metrics than ExpertPromptShell with larger LLMs. For instance, in the Equifax environment, ExpertPromptShell with Sonnet 4 was able to exfiltrate a single file, but Incalmo with Haiku 3.5 was able to exfiltrate all 25 databases in the environment. In contrast to the sentiment that larger model sizes are more critical for performance [10], [32], in the red team domain, we see Incalmo’s abstractions are more critical than model size.

Impact of high-level tasks. First, we create a version of Incalmo without high-level tasks, Incalmo-WHT, where LLMs do not have access to the five high-level tasks, but can use the environment and attack graph services. Here, LLMs can perform 19 predefined low-level tasks, such as reading a file or exploiting Apache Struts.¹⁴ These low-level tasks mirror the library that Incalmo uses to translate high-level tasks.

Finding 3.A: Incalmo-WHT was unable to succeed across all 10 environments and 10 LLMs, suggesting that the high-level task abstraction is an important factor for red team success (not shown for brevity).

Impact of Incalmo services. Next, we create a variant of Incalmo without the environment and attack graph services called Incalmo-WS, but LLMs still have access to the five high-level tasks. Incalmo-WS’s agents still use the environment and attack graph services to be environment-

14. We require the system to use predefined tasks to enable the environment and attack graph services.

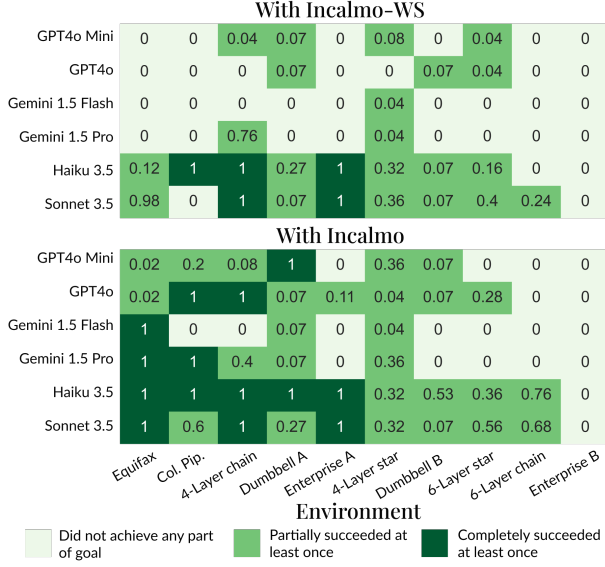


Figure 13. Success and TotalAcquisition metrics of Incalmo and Incalmo-WS. Incalmo was able to succeed in 1–5 more environments than Incalmo-WS. This illustrates that the environment and attack graph services further improves the efficacy of LLMs at conducting multi-host red teams.

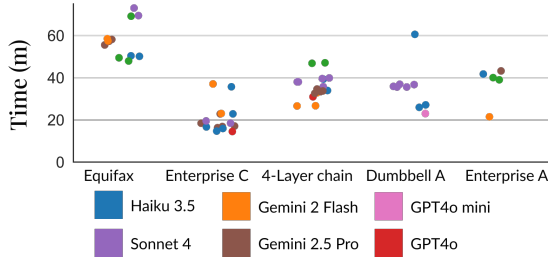


Figure 14. Minutes taken for Incalmo to obtain all critical assets. Incalmo red teams range from taking 14 to 70 minutes.

agnostic, but the services are not accessible to the LLM (unlike Incalmo).

In Fig. 13, we compare Incalmo-WS to Incalmo across a variety of LLMs. Unlike Incalmo-WHT, Incalmo-WS was sometimes able to obtain critical assets. However, in terms of Success, Incalmo was able to succeed in 1 to 5 more environments.

Finding 3.B: In terms of the Success metric, Incalmo was able to succeed in 1 to 5 more environments than Incalmo-WS, suggesting that Incalmo services can further improve red team success (Fig. 13).

For instance, Incalmo-WS with GPT4o mini only obtained critical assets in three environments. In contrast, Incalmo with GPT4o obtained critical assets in eight environments.

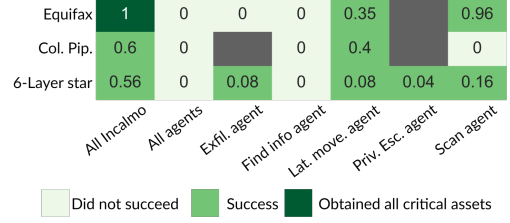


Figure 15. The Success and TotalAcquisition metrics of Incalmo with Sonnet 3.5 task agents in three environments. Sonnet 3.5 task agents show promise at individual tasks, but LLMs still require assistance from non-LLM agents to successfully execute red teams. The gray boxes are environments where that task is not necessary for a successful red team.

6.3. Cost and speed

Next, we measure the speed and cost of Incalmo. In terms of speed, Incalmo can rapidly run red team exercises. For instance, in the Enterprise C environment, Incalmo is able to successfully gain root access on all 15 critical hosts in 12 to 18 minutes (Fig. 14). Similarly, Incalmo can exfiltrate data from all 48 databases in the Equifax-inspired environment in just 54 minutes.

However, some LLMs were inefficient in the red team exercise. For instance, in one trial of Dumbbell A, Incalmo-Haiku 3.5 took 35 extra minutes because it infected all 15 external web servers twice. Incalmo-Haiku 3.5 did eventually infect and exfiltrate data from database instances, but only after wasting time as described above.

Overall, running autonomous red team exercises on multi-host networks with Incalmo is relatively inexpensive. For instance, the Incalmo-Gemini 2 Flash usage is within the free tier. The most expensive Incalmo experiment used Sonnet 3.5 with 5,750K input tokens and 60K output tokens; or around \$15. A breakdown of tokens used by Incalmo is in Appendix C.

Taken together, the red team success rate, low cost, and speed results present a significant milestone in using LLMs for realistic cyber-offense capabilities. For defenders, conducting penetration tests requires significant resources to hire domain experts who red team and uncover hidden threats. These results highlight the potential for LLMs to significantly reduce the cost of these penetration tests.

6.4. Extensibility case study

Next, we demonstrate how Incalmo is extensible to support new task-specific agents. In the prior evaluations, tasks are executed by deterministic agents. In this case study, we explore adding LLM-based task agents to Incalmo. For example, when the planning LLM initiates a lateral movement task, instead of using the predefined Incalmo agent, we consider introducing a new LLM-based agent to dynamically execute the task with low-level commands, but still has access to helpful services like the C&C server service. For the case study, we design an LLM-based agent for each of the five tasks.

As an illustration, we show the setting of Incalmo with Sonnet 3.5 to both plan the red team and have the LLM-based task agents use Sonnet 3.5 in three environments: Equifax-inspired, Enterprise C, and 6-layer star. (We see similar results for Sonnet 4, the top performing model.) To bound the cost, we limit each LLM-based task agent to 10 interactions for each task. We consider two experimental setups: (1) *all* task agents use Sonnet 3.5 instead of Incalmo and (2) replace Incalmo task agents *one at a time*.

Finding 4: Sonnet 3.5-based task agents show promise at executing lateral movement, network scanning, privilege escalation, and data exfiltration. But LLM planners still require assistance from non-LLM agents to succeed (Fig. 15).

In the “all” setup, Sonnet 3.5 as the planner only using Sonnet 3.5 task agents was unable to succeed in any of the 3 evaluated environments, as seen in Fig. 15. However, when replacing a single Incalmo agent for LLM-based agents, Sonnet 3.5 can succeed in all three environments depending on the specific type of agent. For instance, Sonnet 3.5 with a Sonnet 3.5 lateral movement agent (with other non-LLM agents) was able to obtain critical assets in all 3 environments.

This study also serves two other purposes. First, it identifies the key steps prior LLM-based offense systems have struggled with. Second, it suggests a roadmap to tackle 0-day vulnerabilities via novel AI-based agents when the existing agents lack coverage [73].

7. Discussion and limitations

Next, we briefly discuss limitations and directions for improving the capabilities in Incalmo.

Improve TotalAcquisition. We saw that Incalmo was unable to obtain *all* critical assets in some exercises. In some cases, the LLM planner obtained a single critical asset and then stopped. In many trials, we observed the LLM planner could have queried the Incalmo attack graph service to identify that there were additional paths to explore, but did not do so. We speculate this could be because LLMs may not have much training data for red teaming multi-host networks using attack graphs. An interesting direction for future work is to improve coverage (e.g., further train and fine-tune LLMs to better leverage the attack graph service).

Reducing failure scenarios. We saw Incalmo was unable to succeed in 3 environments. On further analysis, we found that these settings required both external scans (e.g., to identify vulnerable web servers) and internal scans (e.g., to identify a vulnerable database management server). At a high level, the current LLM-assisted workflow seems to lack an understanding that scanning from different network locations could have different results. We hypothesize that this can be addressed by improving the Incalmo attack graph service to reason about network segments and access control (e.g., need to be on same subnet to access a host because

of inter-segment firewalls). We believe that extending the attack graph service to reason about fine-grained access control could further improve Success and also help improve TotalAcquisition.

Extending Incalmo to handle 0-days. In this paper, we scoped our exploration to consider exercises with known vulnerabilities. Since Incalmo is extensible, future versions could support advanced 0-day specific task agents to further improve red team effectiveness [73].

Environment realism. In general, enterprise network details are considered sensitive and there is little public information. MHBench is our best effort attempt using a variety of public sources and prior reports to design realistic environments [43], [33], [2], [18]. An interesting direction of future work is to extend MHBench and use Incalmo on a broader range of real (possibly proprietary) enterprise settings at scale.

Adding defenders in the loop. As a first step toward understanding the feasibility of LLM-assisted red teaming in multi-host network settings, we evaluate Incalmo in environments without defenders. An interesting direction for future work is to extend this to settings with realistic (and possibly autonomous) defenses in place and also add features to Incalmo to evade detection.

Memorization. A concern with LLMs is the memorization of training data. Given that the prior LLM-offense systems failed in MHBench, they may have not been exposed to multi-host network challenges. In contrast, LLMs’ success with CTF challenges [80], [14], [71], [49] may be due to publicly available solutions in training data. However, as MHBench will be released, LLM providers may incorporate MHBench in the training data. Similar to other efforts [1], we envision MHBench as evolving and using “holdout” tests in the future.

8. Other related work

We discussed most of the closely related work on LLM-assisted cyber offense capabilities in Sec. 2. Before we conclude, we briefly discuss other related work.

LLM security benchmarks. As mentioned in Sec. 2, there are many benchmarks for evaluating LLMs in CTF challenges (e.g., [61], [76], [72], [72], [7], [56]). However, they are challenge problems and single host attacks. Other non-CTF benchmarks evaluate general security knowledge (e.g., [68]).

Other research in LLMs for security. In addition, there is work to create LLM-based systems for other security tasks. For instance, there is work evaluating LLMs ability to find vulnerable code (e.g., [72]), using LLMs to summarize defender security logs (e.g., [13]), and using LLMs for anomaly detection (e.g., [15]). Other work has shown how LLMs can be used for social engineering tasks like phishing [57], [25]. These are orthogonal to our focus on multi-host red teams.

9. Conclusions

We identify a key gap in existing LLM-based offense capabilities: autonomously executing red teaming exercises in multi-host environments. We showed that state-of-the-art LLM-assisted cyber offense systems struggle in this setting and shed light on the key failure modes of existing solutions. By raising the level of abstraction via decoupling of planning and execution and introducing domain-specific task agents, Incalmo demonstrates the feasibility of LLM-assisted red teaming in complex multi-host settings. Across a majority of the diverse environments in MHBench, Incalmo can autonomously find vulnerable services, execute exploits, gain access to networks, discover configurations and vulnerabilities to laterally move, exploit vulnerabilities to escalate privileges, and exfiltrate data.

We believe Incalmo and MHBench represent a significant advance in our understanding of LLM-assisted red teaming capabilities in realistic multi-host settings. We believe that by lowering the barrier for defenders to run red teaming exercises quickly, cheaply, and often, we can better enable them to proactively protect their networks against future attacks (both human and AI-based). We hope our work spurs further advances in the “science of security” in the use of AI-assisted autonomous cyber defense and offense capabilities.

Ethics considerations

In computer security, there is a history of developing dual-use technologies [64], [53]. For example: fuzzing can find bugs for defenders to patch or attacker to exploit, malware research can help defenders detect malware or attackers evade malware detection, and adversarial ML techniques can help defenders train better models or help attackers trick existing models. In many cases, such dual-use technologies benefit defenders more than attackers [64], [53].

We acknowledge that Incalmo follows this trend as a dual-use technology: defenders can use Incalmo to proactively test their networks to discover security gaps or real attackers can use Incalmo to attack networks. Incalmo poses similar risks as other tools in this space such as prior LLM-based attack systems [80], [14], [44], [73] and non-LLM attack systems [8], [19], [16], [45].

However, understanding the limits of AI-assisted autonomous attacks can benefit red teams as shown in this paper. It will also help defenders guard against future AI-assisted attackers by helping them play on a level footing by proactively assessing vulnerabilities and security gaps in their networks. Finally, we believe that understanding the limits and capabilities of LLM-assisted offense capabilities whether for red teaming or attacks, is valuable to advance the science of AI-meets-security for key stakeholders across academia, industry, governments, and policymakers.

Next, we primarily discuss the ethical principle of beneficence with respect to several key stakeholders because it is the most relevant:

- **LLM providers** LLM providers could both benefit and face harm from this research. LLM providers could benefit by profiting off of future Incalmo-like tools that use LLMs to find security gaps in networks. This research could also harm the reputation of providers if bad actors utilize LLMs to maliciously hack networks using LLMs. Furthermore, the research could impact the profits of providers if policymakers decide to regulate the usage of LLMs based on our findings.
- **Companies** Similar to LLM providers, companies could both benefit and face harm from this research. Companies already use non-LLM autonomous attack tools [19], [8] to find gaps in their security. Similarly, companies could use the results of this research for the same purpose. However, similar to other autonomous attack tools, bad actors could use these tools to cause harm against companies such as a cyber attack.
- **Policymakers** There is great interest in regulating AI technology by government organizations and policymakers. Incalmo and MHBench can assist policymakers in measuring the red teaming capability of LLMs. Many government agencies and frontier labs are already evaluating other cybersecurity capabilities of LLMs [71], [80], [49] to help inform their policies and our research further sheds light on these capabilities.
- **Security vendors** Security vendors could benefit from Incalmo helping them assess networks for security gaps. Their customers could benefit from dramatically lowered cost, time, and effort needed to launch complex red teaming exercises.
- **Society at large** As society becomes more dependent on technology, the security risks increase. Autonomous attack tools can both help prevent these security risks and lower the bar for bad actors to execute attacks.

Decision. We decided to proceed with this research because we believe the benefits of autonomous red teaming outweigh the potential harms. Our belief is consistent with similar prior systems [14], [80], [8], [75], [28], [54], [35], [73] and the analysis of that practice in computer security research [64]. Furthermore, we also mitigated the risks to LLM providers by preemptively notifying the providers to add guardrails if they choose to do so.

Open Science. In addition, reproducibility and transparency are key tenets to scientific research [48]. Open source code both assists researchers to reproduce this work and accelerates scientific progress. As a result, similar to other prior offensive systems [14], [80], [8], [54], [44], MHBench, our tools to reproduce prior work, and Incalmo will be open source and publicly available to the research community: <https://github.com/bsinger98/Incalmo>.

LLM usage considerations

Originality: LLMs were used for editorial purposes in this manuscript, and all outputs were inspected by the authors to ensure accuracy and originality.

Transparency: We evaluated Incalmo with both open- and closed-source LLMs, but we only observed meaningful

results with the closed-source models. We acknowledge that closed-source LLMs may make some of the results harder to reproduce. However, we mitigate this limitation by open-sourcing MHBench, prompts, model numbers, and Incalmo's code. We also show in Sec. 6 that Incalmo performs well across a diverse range of LLMs. As open-source LLMs increase in capabilities, we envision these models could be used instead of closed-source LLMs.

Responsibility: We are unable to calculate exact carbon footprints for our experiments [31]. Experiments cost at most \$15 of credits and in total we spent around \$3,000 of LLM credits across providers. We also took care to design and debug Incalmo on smaller LLMs before executing thorough evaluations to minimize the environmental impact. Furthermore, cyberattacks are extraordinarily costly (in terms of money, energy, human harm, etc) for society [20], [33]. As a result, we conclude that the potential benefits of reducing the cost of red teaming networks to proactively find security gaps outweigh the environmental impact of the research.

References

- [1] Humanity's Last Exam. <https://agi.safe.ai/>, accessed: Apr 23, 2025.
- [2] Enterprise Campus 3.0 Architecture: Overview and Framework. Technical report, Cisco, April 2008.
- [3] Hierarchical Tree Topology. Technical report, IBM, January 2024.
- [4] A. B. Ajmal, M. A. Shah, C. Maple, M. N. Asghar, and S. U. Islam. Offensive security: Towards proactive threat hunting via adversary emulation. *IEEE Access*, 2021.
- [5] H. S. Al-Sinani and C. J. Mitchell. Pentest++: Elevating ethical hacking with ai and automation. *arXiv:2502.09484*, 2025.
- [6] Anthropic. Threat intelligence report: August 2025. Technical report, Anthropic, San Francisco, CA, USA, Aug. 2025. Available at <https://www-cdn.anthropic.com/b2a76c6f6992465c09a6f2fce282f6c0cea8c200.pdf>.
- [7] A. Anurin, J. Ng, K. Schaffer, J. Schreiber, and E. Kran. Catastrophic cyber capabilities benchmark (3cb): Robustly evaluating llm agent cyber offense capabilities. *arXiv:2410.09114*, 2024.
- [8] A. Applebaum, D. Miller, B. Strom, C. Korban, and R. Wolf. Intelligent, Automated Red Team Emulation. In *Proceedings of the 32nd Annual Conference on Computer Security Applications*, 2016.
- [9] L. Bilge and T. Dumitras. Before we knew it: an empirical study of zero-day attacks in the real world. In *ACM CCS*, 2012.
- [10] T. B. Brown. Language models are few-shot learners. *arXiv:2005.14165*, 2020.
- [11] M. Cemri, M. Z. Pan, S. Yang, L. A. Agrawal, B. Chopra, R. Tiwari, K. Keutzer, A. Parameswaran, D. Klein, K. Ramchandran, et al. Why do multi-agent llm systems fail? *arXiv:2503.13657*, 2025.
- [12] M. Corporation. MITRE ATT&CK® Framework. <https://attack.mitre.org/>.
- [13] M. Corporation. Microsoft Security Copilot, 2023.
- [14] G. Deng, Y. Liu, V. Mayoral-Vilches, P. Liu, Y. Li, Y. Xu, T. Zhang, Y. Liu, M. Pinzger, and S. Rass. PentestGPT: Evaluating and Harnessing Large Language Models for Automated Penetration Testing. In *USENIX*, 2024.
- [15] A. Elhafsi, R. Sinha, C. Agia, E. Schmerling, I. A. Nesnas, and M. Pavone. Semantic anomaly detection with large language models. *Autonomous Robots*, 47(8):1035–1055, 2023.
- [16] S. Y. Enoch, Z. Huang, C. Y. Moon, D. Lee, M. K. Ahn, and D. S. Kim. Harmer: Cyber-attacks automation and evaluation. *IEEE Access*, 8:129397–129414, 2020.
- [17] R. Fang, R. Bindu, A. Gupta, Q. Zhan, and D. Kang. Teams of llm agents can exploit zero-day vulnerabilities. *arXiv:2406.01637*, 2024.
- [18] K. J. Ferguson-Walter, M. M. Major, C. K. Johnson, and D. H. Muhleman. Examining the efficacy of decoy-based and psychological cyber deception. In *USENIX*, 2021.
- [19] Fortra. Cobalt Strike. <https://www.cobaltstrike.com/>.
- [20] FTC. Equifax Data Breach Settlement. Technical report, December 2022.
- [21] L. Gao, A. Madaan, S. Zhou, U. Alon, P. Liu, Y. Yang, J. Callan, and G. Neubig. Pal: Program-aided language models. In *International Conference on Machine Learning*. PMLR, 2023.
- [22] L. Hackländer-Jansen. Emulating complete, realistic cyber attack chains with the new caldera bounty hunter plugin, 2024. Medium (MITRE Caldera). Accessed: 2025-11-11.
- [23] A. Happe and J. Cito. Getting pwn'd by ai: Penetration testing with large language models. In *ACM ESEC*, 2023.
- [24] A. Happe and J. Cito. Can llms hack enterprise networks? autonomous assumed breach penetration-testing active directory networks. *ACM TOSEM*, 2025.
- [25] F. Heiding, S. Lermen, A. Kao, B. Schneier, and A. Vishwanath. Evaluating Large Language Models' Capability to Launch Fully Automated Spear Phishing Campaigns: Validated on Human Subjects. *arXiv:2412.00586*, 2024.
- [26] H. Holm. Lore a red team emulation tool. *IEEE Transactions on Dependable and Secure Computing*, 2022.
- [27] H. Holm and T. Sommestad. SVED: Scanning, vulnerabilities, exploits and detection. In *MILCOM 2016 IEEE Military Communications Conference*. IEEE, 2016.
- [28] Z. Hu, R. Beuran, and Y. Tan. Automated penetration testing using deep reinforcement learning. In *IEEE EuroS&PW*. <https://github.com/crond-jaist/AutoPentest-DRL>.
- [29] J. Huang and Q. Zhu. PenHeal: A Two-Stage LLM Framework for Automated Pentesting and Optimal Remediation. In *Proceedings of the Workshop on Autonomous Cybersecurity*. Association for Computing Machinery, 2024.
- [30] E. M. Hutchins, M. J. Cloppert, R. M. Amin, et al. Intelligence-driven computer network defense informed by analysis of adversary campaigns and intrusion kill chains. *Leading Issues in Information Warfare & Security Research*, 2011.
- [31] N. Jegham, M. Abdelatti, L. Elmoubarki, and A. Hendawi. How hungry is ai? benchmarking energy, water, and carbon footprint of llm inference. *arXiv:2505.09598*, 2025.
- [32] J. Kaplan, S. McCandlish, T. Henighan, T. B. Brown, B. Chess, R. Child, S. Gray, A. Radford, J. Wu, and D. Amodei. Scaling laws for neural language models. *arXiv:2001.08361*, 2020.
- [33] S. M. Kerner. Colonial Pipeline hack explained: Everything you need to know. *TechTarget*, 2022.
- [34] H. Kong, D. Hu, J. Ge, L. Li, T. Li, and B. Wu. Vulnbot: Autonomous penetration testing for a multi-agent collaborative framework. *arXiv:2501.13411*, 2025.
- [35] M. Kouremetis, M. Dotter, A. Byrne, D. Martin, E. Michalak, G. Russo, M. Threet, and G. Zarrella. Occult: Evaluating large language models for offensive cyber operation capabilities. *arXiv:2502.15797*, 2025.
- [36] M. Kouremetis, D. Lawrence, R. Alford, Z. Cheuvront, D. Davila, B. Geyer, T. Haigh, E. Michalak, R. Murphy, and G. Russo. Mirage: cyber deception against autonomous cyber attacks in emulation and simulation. *Annals of Telecommunications*, 2024.